



UNIVERSITY OF
CAMBRIDGE



**Bennett School
of Public Policy**

The University of Cambridge
Bennett School of Public Policy

The Parameterisation of Privacy: Closing the
Accountability Gap in Privacy-Preserving AI

Alyssa Jo Tice
June 7, 2026

Table of Contents

Executive Summary	3
Part 1: Technical Context	5
<i>Machine learning.....</i>	<i>5</i>
<i>Federated learning</i>	<i>5</i>
<i>Differential privacy</i>	<i>6</i>
<i>Epsilon: the privacy parameter.....</i>	<i>6</i>
Part 2: Problem Definition & Policy Background.....	6
Part 3: Methodology	11
Part 4: Results and Policy Implications	13
Part 5: Discussion	15
Part 6: Policy Options	16
<i>Option 1: Mandatory epsilon disclosure for federated learning deployments</i>	<i>17</i>
<i>Option 2: Proactive DPIA Submission Requirement for FL Deployments</i>	<i>18</i>
<i>Option 3: A federated learning pilot programme within the ICO regulatory sandbox.....</i>	<i>18</i>
<i>Option 4: ICO privacy engineering unit.....</i>	<i>19</i>
<i>Option 5: FL+DP as a preferred transfer mechanism</i>	<i>20</i>
Part 7: Policy Recommendations & Implementation	20
Part 8: Conclusion.....	22
References	23
Appendix A: Model Design	29
Appendix B: Results Table	33
Appendix C: Confidence Intervals.....	34
Appendix D: McNemar’s Test.....	36

Executive Summary

Subject: Closing the Accountability Gap in Privacy-Preserving AI

To: United Kingdom Information Commissioner's Office

From: Senior Policy Adviser

Problem Statement

Data protection laws like the UK's General Data Protection Regulation (GDPR) establish high-level principles for privacy protection but leave technical compliance mechanisms to the discretion of the firms implementing them. This leaves the practical strength of privacy protection to be determined not by regulators or lawmakers, but by the technical discretion of engineers who have no requirement to justify their choices. The parameterisation of these legal principles leaves a translation gap between what the law requires and what engineers actually implement. This is where accountability is currently lacking, and where GDPR's deliberate technology-neutrality has produced ambiguity that both firms and regulators struggle to resolve.

Analysis

This paper focuses on the selection of epsilon, the parameter that controls the strength of differential privacy in federated machine learning systems. Epsilon is not specified by law, is not disclosed in regulatory assessments, and is chosen internally by technical teams whose commercial incentives favour accuracy over privacy. Using a self-developed federated learning model trained on synthetic health data, this paper demonstrates that the privacy-utility trade-off is real and consequential: at the epsilon values where the model retains clinical utility ($\epsilon \geq 10$), the privacy guarantee for sensitive data is weak; at the values where privacy protection is meaningful ($\epsilon \leq 1$), the model loses most of its diagnostic value. Under current ICO guidance, any of these values is compliant, and firms have no obligation to disclose or justify their choice. Regulators have no visibility into which epsilon a firm has selected, no mechanism to require its disclosure, and in most cases insufficient technical expertise to evaluate it if they did. The UK is well-positioned to address this. Post-Brexit regulatory independence, the Data (Use and Access) Act 2025, and the ICO's 2025 AI and Biometrics Strategy create the conditions for a more substantive approach to technical oversight: one that supports innovation while closing the accountability gap.

Recommendations: This paper recommends three complementary policy interventions, sequenced by time horizon, that together move epsilon selection from an unaccountable technical choice to a governable policy decision.

1. Mandatory epsilon disclosure

The ICO should issue updated DPIA guidance requiring disclosure of epsilon values for federated learning deployments processing special category data. This is achievable within 3–6 months under the ICO's existing powers and requires no new legislation.

2. Regulatory sandbox

The ICO should build on its existing regulatory sandbox infrastructure to open a dedicated sandbox research area for organisations deploying FL+DP. Over a three-year period, the programme would test epsilon selection across a range of deployment contexts, with technical staffing expanded incrementally as participation grows. The sandbox would generate the evidence base currently absent from this area of regulation.

3. Preferred mechanism designation

Drawing first on disclosure data and then on sandbox findings, the ICO should publish an approved epsilon range and formally designate FL+DP as a preferred mechanism for compliance with Article 25 of the UK GDPR, the provision requiring data protection to be built into processing by design. This gives firms a clear compliance pathway and makes the UK a more attractive jurisdiction for privacy-preserving AI deployment.

Part 1: Technical Context

This section provides the technical background necessary to understand the policy problem this paper identifies.

Machine learning

Machine learning is a category of artificial intelligence where a system learns to make predictions by identifying patterns in large datasets (Jordan & Mitchell, 2015). In healthcare, machine learning models are increasingly used to predict diagnoses, determine at-risk patients, and support clinical decision-making. A 2022 review found that machine learning diagnostic tools matched or exceeded clinician accuracy across a range of conditions including diabetic retinopathy, skin cancer, and sepsis prediction (Rajpurkar et al., 2022). The performance of these models depends on the volume and quality of data they are trained on.

Federated learning

In the United Kingdom and European Union, the General Data Protection Regulation (GDPR) classifies health data as a special category of personal data subject to the strictest protections under Article 9 (UK GDPR, Article 9). Institutions wishing to share patient records for research purposes must establish a lawful basis for processing, conduct data protection impact assessments (DPIAs), and in most cases obtain explicit patient consent. If the institutions are in different countries or geographical areas, it may be impossible to use data for research purposes (Rieke et al., 2020). Federated learning (FL) was proposed as a technical solution to this problem. Rather than moving patient data to a central server for training, federated learning keeps the data in place at each institution. Each hospital trains the model locally on its own patients, and only the resulting model updates are shared with a central aggregation server. The server combines these updates into an improved global model, which is then redistributed to each hospital for the next round of training. At no point does raw patient data leave the institution where it originated (McMahan et al., 2017).

This architecture has attracted significant interest from regulators and institutions because it appears to satisfy GDPR's requirements for cross-border data sharing (UK GDPR, Article 9). Federated learning is already being used at scale in healthcare research. The Machine Learning Ledger Orchestration for Drug Discovery (MELLODDY) project used federated learning to train drug discovery models across ten pharmaceutical companies without any company sharing its proprietary data (Oldenhof et al., 2023). The European Federation for Cancer Images (EUCAIM) project is building a federated cancer imaging platform spanning twenty-four member states, allowing models to be trained on patient scans that never leave their country of origin (Cancer Image Europe, n.d.). In the United Kingdom, the NHS has piloted federated data infrastructure approaches for population health analytics through the Federated Data Platform, which allows NHS trusts to contribute to national models while retaining local control over patient records (NHS England, n.d.). Federated learning reduces the risk of exposing patient data, but it does not eliminate it entirely. Researchers have shown that it is possible to reconstruct individual patient records by carefully analysing the model updates that hospitals share during training, even though those updates contain no raw data (Zhu et al., 2019). This means that federated

learning alone is not sufficient as a privacy guarantee, which is where differential privacy comes in.

Differential privacy

Differential privacy is a technique that adds carefully calibrated random noise to model updates before they are shared, making it more difficult to determine whether a specific patient's data was used in training (Dwork et al., 2006). The noise is large enough to protect any individual's contribution, but small enough that the overall statistical signal remains useful. For example, an attacker who knows a patient is 67 years old could search a dataset for that value and potentially identify them. With differential privacy, random noise is added to each age value before the data is used in training, so the 67-year-old might appear as 64, or 71. Any individual record is plausibly deniable. Across thousands of patients, the statistical distribution of ages remains accurate enough for the model to learn from, but no individual can reliably locate themselves in the data. The result is a formal guarantee that even an attacker with unlimited computing power cannot reliably determine whether any specific patient was included in the training data (Abadi et al., 2016). This approach comes with trade-offs. More noise means stronger privacy but less accurate results, because the same noise that hides individual patients also obscures genuine patterns in the data. Less noise means better accuracy but weaker privacy. The parameter that controls this balance is epsilon.

Epsilon: the privacy parameter

Different amounts of random noise can be added to the training data to add more privacy. The more random noise added, the less accurate the model will be and the more private the data. If no random noise is added, the model will be more accurate, but there is an increased risk of reidentifying the data (Dwork et al., 2006). The strength of privacy is described by a parameter called epsilon (ϵ). Epsilon measures how detectable an individual's data is in the model. If the same federated model is run twice, once with a dataset that includes a specific patient, and once with that patient removed, then epsilon determines the maximum difference the two runs can produce. A small epsilon means the two outputs are nearly identical, so an observer cannot tell whether that patient was included. A large epsilon means the outputs can differ substantially, meaning the patient's presence is potentially detectable (Dwork et al., 2006). As Apple's own team describes it, 'the smaller the epsilon, the stronger the privacy protection — but the more noise must be added to the data, and the less accurate the results become' (Apple Differential Privacy Team, 2017). The epsilon scale runs from zero to infinity, but it is not linear. At $\epsilon=0$, privacy would be perfect but the model would be useless because predictions would be influenced by the noise. At very high values, the privacy guarantee is so weak it offers no meaningful protection. The practically relevant range sits roughly between $\epsilon=0.1$ and $\epsilon=10$ (Ponomareva et al., 2023).

Part 2: Problem Definition & Policy Background

The EU and UK GDPR establishes principles such as data minimisation, purpose limitation, and “privacy by design”, but intentionally avoids specifying the technical parameters required to comply with those principles (UK GDPR). This technology-neutral approach reduces the

compliance burden on firms, enables innovation without regulatory permission, and allows the law to accommodate technologies that did not exist when it was drafted. The consequence of this design is that the practical meaning of privacy protection is not determined by law, but rather by the engineers who implement it. This paper examines the parameterisation of legal principles, which is the process by which abstract legal obligations are translated into concrete technical values by engineers. This technical discretion is where privacy protection is really decided, and where accountability is currently absent.

Privacy protection is not an abstract legal obligation. For example, in the healthcare space, it has direct consequences for patients. When patients fear that their medical data may be exposed or misused, they avoid seeking care, particularly for stigmatised conditions such as mental health disorders and substance use (Brown et al., 2022). A federated learning model that inadequately protects patient privacy does not just create a legal liability; it risks undermining the trust that makes health data sharing possible in the first place. The NHS has already faced significant public backlash over data sharing arrangements, including the Palantir Federated Data Platform contract, demonstrating that public trust in health data governance is fragile and consequential (Kerasidou & Kerasidou, 2023). Healthcare is used here as an illustrative case, but the same problem applies wherever personal data is used to train machine learning models. GDPR was designed precisely to give individuals meaningful control over their data and protect them from its misuse. If these technical decisions are made without regulatory oversight, the law cannot fulfil its purpose.

GDPR requires that data is "effectively anonymised" before it can be shared freely, but it does not specify what anonymisation means (UK GDPR, Article 4). Firms choose their own thresholds for anonymisation techniques, and those choices determine whether individuals are genuinely protected (Sweeney, 2002). Research has demonstrated that datasets declared anonymous can be re-identified with modest effort, suggesting that industry-set anonymisation thresholds are frequently insufficient (Narayanan & Felten, 2014). Another example of technical parameterisation under GDPR is the requirement that consent to data processing be "freely given, specific, informed and unambiguous", but GDPR does not specify what a consent interface must look like (UK GDPR, Article 4). The technical design of cookie banners and opt-in flows is left to the firm. Research has shown that interface designs that nudge users toward privacy-invasive choices are widespread, and that the difference is an engineering decision that regulators have little oversight over (Mathur et al., 2019; Nouwens et al., 2020). In both cases, a legal obligation has been translated into a technical parameter that is set by the firm, and the regulator has no prescribed standard against which to assess it.

These examples raise an important question: is regulatory specificity desirable, or even possible? The technology-neutral design of GDPR was a deliberate choice. Prescribing specific technical parameters in legislation risks stifling innovation and creating compliance requirements around outdated standards. **There is an argument that leaving technical discretion to firms is not a failure of the framework but a feature of it.** This regulation sets the goal and trusts industry to find the best path to it. Authoritarian regimes such as China have pursued strict technical regulation of AI through mandatory algorithm registries, specific

localisation requirements, and content rules built into model design (Sheehan, 2023). These offer firms clearer compliance rules at the cost of restricting what can be built. Democracies have generally resisted this approach, both because rapid prescriptive rulemaking sits uneasily with legislative process and because broad principles allow law to remain durable across changing technologies and administrations. The challenge for democratic regulators is balancing principles-based law supported by evidence-based technical standards. Regulation cannot, and should not, specify everything, but there may be some categories of technical decision where the parameters are concrete enough that some degree of regulatory specification is warranted. This paper argues that the epsilon values used in federated learning are one such case: a quantifiable value with a direct relationship to privacy risk.

In response to data sharing and data residency constraints created by GDPR, federated learning is a technical approach for cross-institutional machine learning in healthcare and other applications that involve pooling data across jurisdictions (Rieke et al., 2020). Because raw patient data never leaves the institution where it was collected, federated learning appears to satisfy GDPR's cross-border transfer restrictions (McMahan et al., 2017). Federated learning offers a solution to data sovereignty issues by ensuring that raw data never leaves the local jurisdiction. For this reason, federated learning is now widely framed in both academic literature and industry practice as a GDPR-compatible path to collaborative healthcare AI (Rieke et al., 2020; Kaissis et al., 2021). Combining differential privacy with federated learning has become the dominant approach in privacy-preserving machine learning research and is recommended as best practice for federated systems handling sensitive personal data (Ponomareva et al., 2023). However, while the technical combination is well established, there is no agreed upon standard for what epsilon value should actually be chosen. The Information Commissioner's Office (ICO) recommends Privacy Enhancing Technologies (PETs) as part of a compliance toolkit but is explicit that the choice of specific technical parameters depends on the organisation's "particular circumstances". This leaves the question of what epsilon to use unresolved (Information Commissioner's Office, 2023).

The result is that firms are free to choose the epsilon value they consider appropriate. Apple deploys differential privacy across its devices using different epsilon values for different data types: published figures range from $\epsilon=2$ to $\epsilon=4$, though independent researchers who reverse-engineered Apple's implementation found values as high as $\epsilon=14$ (Tang et al., 2017). Academic researchers typically use $\epsilon=1$ as a rough threshold for strong privacy, though this reflects convention rather than a regulatory standard (Ponomareva et al., 2023). A 2014 paper on the problem of choosing epsilon concluded that there is no rigorous method for selecting the parameter in practice (Hsu et al., 2014). In the absence of regulatory guidance, **epsilon selection defaults to machine learning engineers**, the people with the strongest technical understanding, least amount of legal and regulatory knowledge, and the weakest incentive to prioritise privacy. A lower epsilon produces a more privacy-protective but less accurate model, and in most commercial deployments, model accuracy is the metric against which engineering teams are evaluated (Ponomareva et al., 2023). This creates a structural pressure toward higher epsilon values.

There is also a transparency problem. Unlike many other compliance decisions, epsilon selection is rarely documented in a form that is accessible to regulators. Data Protection Impact Assessments (DPIAs) are the primary mechanism under GDPR for oversight, but do not require disclosure of epsilon values or any other technical information (UK GDPR, Article 35). A DPIA might say that differential privacy has been applied, but a regulator reviewing such a DPIA would have no basis on which to assess whether the epsilon chosen was appropriate. Most regulators do not have the technical literacy to evaluate a design choice like this (Information Commissioner's Office, 2023). Because of this lack of concrete guidance, GDPR has created tension between data privacy regulation and technological innovation. It impacts consumers, legal teams, and engineering departments when a technology firm deploys a product in the EU or the UK. The GDPR was designed to give individuals control over their personal data and to hold the organisations processing it accountable. Cumulative fines since 2018 now exceed €7.1 billion, with more than 60% of that total imposed since January 2023 (ten Eikelder, 2026). This regulation's influence has spread well beyond Europe, and jurisdictions in California, Brazil, and India have modelled their own frameworks on GDPR. The global trajectory is toward increased privacy regulation for technology (IEEE Digital Privacy, n.d.). GDPR is not going away, and neither is increased regulatory pressure for technological privacy and security.

But the costs of that pressure are real, and they have wide-reaching impact. Meta, Google, and OpenAI have all delayed AI product rollouts across Europe, citing privacy and regulatory hurdles as key barriers (Hawkins, 2025). Meta has stated that the EU has not provided clarity over what GDPR requires for it to use customer data to train AI models (Fried, 2024). Another piece of legislation, the AI Act, came into effect in August 2024, and is the first comprehensive legal framework for artificial intelligence, classifying AI systems by risk level and imposing significant pre-deployment oversight on “high-risk” deployments (Directorate-General for Communication, 2024). For firms deploying machine learning, this means navigating the GDPR and the AI Act simultaneously, two frameworks developed by different parts of the European Commission, whose interaction is not yet fully worked out. Google withdrew from the EU market for political advertising entirely, citing operational challenges and legal uncertainty (Calabrese, 2026). **For some firms and situations, market exit is treated as the only reasonable option to ensure compliance.** This matters economically as well as technologically: Big Tech firms collectively contribute hundreds of billions to European GDP through direct investment, employment, and crucial digital infrastructure, and their partial withdrawal from European markets carries real costs for consumers, businesses, and governments (Kortis et al., 2026). **This indicates that firms find the law genuinely difficult to interpret and apply, particularly in areas where the regulatory framework does not map cleanly onto the technology it is supposed to govern.** These grey areas are a feature of regulations written before current technologies existed.

The European Commission's Digital Omnibus package, proposed in November 2025, acknowledges these tensions directly. The package proposes that AI training and deployment be recognised as a legitimate interest under GDPR, giving firms legal basis to train AI models (European Commission, 2025). A leaked draft proposed narrowing the definition of health data to limit GDPR's scope and increase AI training on health data. That provision was removed following significant pushback (Covington Privacy Team, 2025). This new ruling demonstrates

how acute the pressure has become to improve the clarity and usability of technology under GDPR. Ambiguity is a central problem, and it heavily impacts firms and institutions trying to operate in technically complex domains. The GDPR is genuinely unclear in its application to privacy-preserving AI. Firms do not know whether their FL+DP implementations satisfy GDPR's anonymisation standard, and the compliance mechanisms that are supposed to bridge that gap are inadequate.

The use of federated learning with differential privacy is impacted by GDPR's ambiguity. GDPR's core principles such as anonymisation and data minimisation were drafted before the popularisation of federated software development, and the principles do not transfer cleanly (Truong et al., 2021). A common industry assumption is that FL is inherently privacy-preserving: because raw data never leaves the device, data processing is presumed to fall outside GDPR's personal data framework entirely (Truong et al., 2021). Truong et al. (2021) challenge this directly. Model parameters exchanged during federated training could reveal information about underlying training data. FL-based systems therefore remain within the GDPR regulatory framework and cannot be treated as anonymous data because of their architecture. This ambiguity determines if data used for training federated learning models are even under GDPR's jurisdiction. Under Recital 26, data that has been genuinely anonymised is not considered personal data and falls entirely outside GDPR's scope. Therefore it is not required to uphold any GDPR obligations. This creates an incentive for firms to claim anonymisation: **if the anonymisation holds, the regulatory burden disappears**. Differential privacy has increasingly been invoked to support that claim (Truong et al., 2021). Data is anonymous in the eyes of GDPR if there is no reasonable means of re-identification, a determination that depends on context, dataset size, and the state of available re-identification techniques (UK GDPR, Recital 26). The epsilon value is where this gap becomes concrete: at $\epsilon=1$, a strong anonymisation argument may hold; at $\epsilon=10$ on a dataset of eight hundred patients, it may not. But because no regulator is scrutinising the epsilon value and context being used, firms can invoke differential privacy as an anonymisation mechanism regardless of whether their specific configuration actually achieves that standard.

For federated learning deployments, a DPIA is the primary mechanism through which GDPR is supposed to translate its principles into practice. In practice, the weakness of the DPIA requirement is that it is entirely self-certified. The organisation writes the assessment itself, the Data Protection Officer (DPO) signs it off, and it is then filed internally (UK GDPR, Article 35; Information Commissioner's Office, 2023). The ICO does not routinely review DPIAs before a system goes live. It only sees them if a complaint is filed or a data breach triggers an investigation, by which point the system may have been running for months or years (Information Commissioner's Office, 2023). As Truong et al. (2021) note, a firm can document that differential privacy was applied, file the DPIA, and be fully compliant on paper without anyone checking whether the epsilon value chosen actually provides meaningful protection for the dataset size and data sensitivity involved.

This problem is compounded by who is responsible for signing off on the DPIA. Under GDPR Articles 37 to 39, organisations processing special category data at scale must appoint a Data

Protection Officer. The DPO is responsible for overseeing compliance, advising on data protection obligations, and reviewing DPIAs before they are filed. GDPR specifies that DPOs must have expert knowledge of data protection law, but there are no technical requirements. In practice, DPOs are often lawyers or information governance professionals (UK GDPR, Articles 37-39). A DPO reviewing an FL deployment can confirm that the correct process was followed and that differential privacy was mentioned. However, they cannot assess whether $\epsilon=10$ is appropriate for a dataset of eight hundred patients. **They do not have the necessary expertise to evaluate that question, and the current governance framework does not require them to.**

The UK is well-positioned to address the current dynamic between regulators and firms. After Brexit, the UK adopted the EU's GDPR but also has regulatory independence from the EU. The UK has the opportunity to develop its own approach to GDPR implementation. Rather than following the EU's AI Act, the UK has deliberately pursued a more pro-innovation framework, which gives responsibility to each sector rather than broad, strict, AI regulation (Department for Science, Innovation and Technology [DSIT], 2023). The Data (Use and Access) Act 2025, introduced amendments to UK data protection law with the aim of simplifying compliance and supporting innovation while maintaining strong privacy standards (Department for Science, Innovation and Technology [DSIT], 2025). In June 2025, the ICO launched a new AI and Biometrics Strategy that focuses on prioritising cooperative engagement with compliant organisations for AI technology (Information Commissioner's Office [ICO], 2025). These moves suggest that the UK is ready to position itself as a jurisdiction where responsible AI innovation is actively enabled. Public attitudes suggest demand for stronger oversight: 72% of UK adults say that laws and regulation would make them more comfortable with AI, a figure that has risen ten percentage points since 2023, suggesting that the public's support for innovation is conditional on meaningful accountability (Ada Lovelace Institute & Alan Turing Institute, 2025).

Epsilon represents a simple case of the technical discretion problem. It is a single number, explicitly chosen by an engineer before training begins, with a direct relationship to privacy risk. Epsilon is a case study for how privacy legislation can successfully oversee privacy risk in these technical, crucial areas of software while supporting innovation. The same problem appears across other privacy-related technologies. In many cases, legal principles are translated into technical parameters by engineers, and DPIAs are not able to evaluate whether that translation is compliant with the regulatory requirements. When legal principles require a technical decision to give practical meaning, there is a regulatory gap. The remainder of this paper focuses on epsilon as a measurable, testable case study of this problem and proposes policy interventions that address it.

Part 3: Methodology

The central claim of this paper is that epsilon selection is a consequential decision that current data protection frameworks do not adequately regulate. To test this empirically, this paper presents a proof-of-concept federated learning model trained on synthetic health data. The model is designed to answer the question: if a firm deployed a differentially private federated learning model under current ICO guidance, what would different epsilon choices produce in

terms of model usability, accuracy, and privacy guarantees? Under current GDPR guidance, any of the epsilon values tested here could be considered compliant, and those compliant choices produce different outcomes. The model demonstrates what the current regulatory framework permits.

The model was trained on synthetic patient data generated using Synthea, an open-source tool that produces fictional patients that eliminates any risk of real patient re-identification while producing clinically plausible data distributions but statistically accurate patient records (Walonoski et al., 2018). Full details of the data generation process, preprocessing pipeline, and partitioning methodology are documented in Appendix A. The model was trained to learn the relationship between BMI, age, biological sex, and the prediabetes diagnosis, so that it could predict whether a new, unseen patient is likely to have prediabetes based on these features.

The different models tested are shown in Figure 1, where they are listed from lower privacy to higher privacy. The first model tested a centralised baseline, in which all patient data is pooled into a single dataset and trained together. This environment is not GDPR compliant and models cross-institutional data sharing that privacy law is designed to prevent. It demonstrates the best accuracy a model could achieve if data protection law did not exist. The second model is a federated baseline, in which patient data never leaves each simulated hospital site and only model updates are shared. This environment represents the current industry standard for GDPR-compatible machine learning in healthcare (Rieke et al., 2020). The third, fourth, fifth, and sixth environments add differential privacy noise at four different intensity levels: $\epsilon=100$, $\epsilon=10$, $\epsilon=1$, and $\epsilon=0.1$. This represents a range from low privacy protection to maximum privacy protection. All four would be considered compliant under current ICO guidance, which recommends differential privacy as a privacy enhancing technology but specifies no required epsilon value. Full implementation details of the model are included in Appendix A.

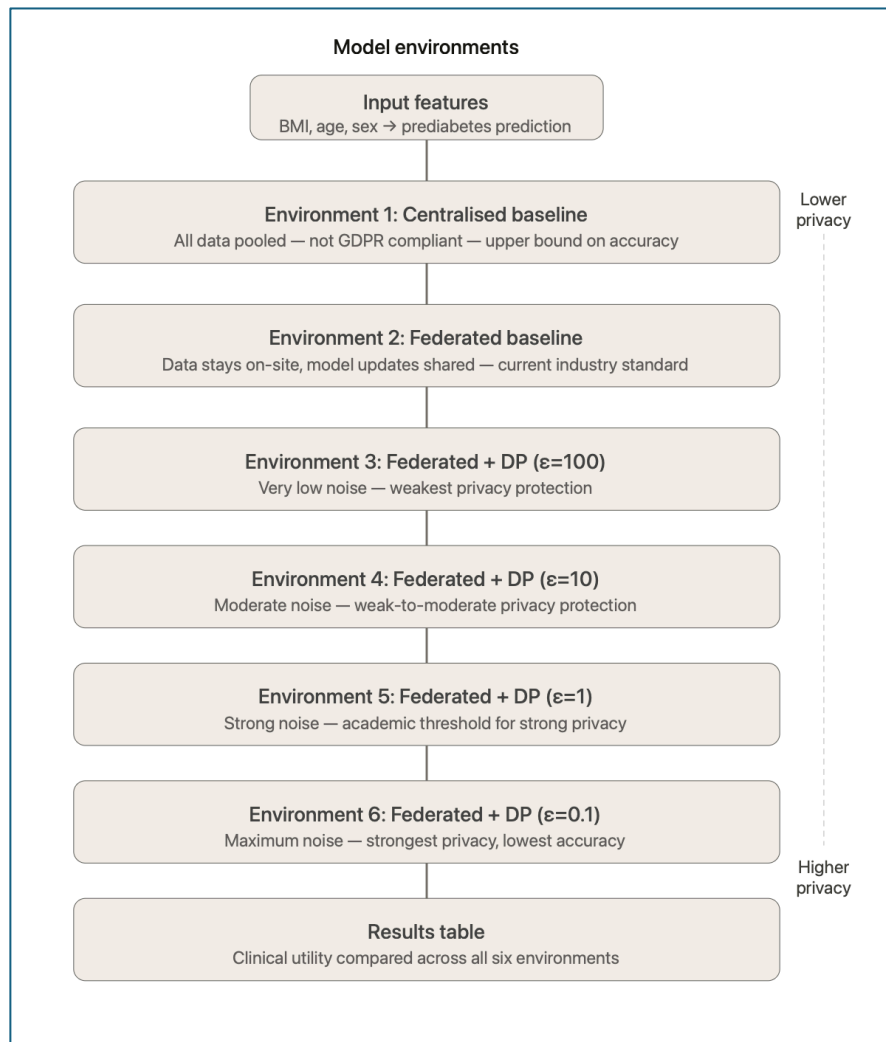


Figure 1: Model environments used in the study, ranging from a centralised baseline (no privacy protection) to federated learning with maximum differential privacy noise ($\epsilon=0.1$).

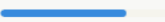
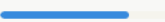
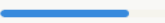
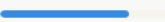
Part 4: Results and Policy Implications

The results are summarised in the table below and in full in Appendix B. The federated baseline test achieved 71.67% accuracy at diagnosing prediabetes on the test data, compared to 72.02% for the centralised baseline. This difference is not statistically significant at the 95% confidence level (see Appendix C). A model trained without any patient data leaving its originating institution performs as well as one trained on fully pooled data. From a policy perspective, this is a positive finding that shows that federated learning is a privacy improvement at almost no accuracy cost. The results also show that differential privacy at moderate epsilon values works. At $\epsilon=100$ and $\epsilon=10$, accuracy was not statistically significantly different from the baseline (see Appendix C). A firm deploying differential privacy at these epsilon values would be providing some amount of privacy guarantee at negligible cost to model performance. This suggests that the ICO's recommendation of differential privacy as a compliance tool is well-founded; models retain clinical utility while providing a meaningful privacy improvement. For the next models

($\epsilon=1$ and $\epsilon=0.1$), the model shows that accuracy and usability significantly drop. At the highest level of privacy guarantee, the model fell to an accuracy level the same as predicting that no patient has prediabetes (Appendix C).

At $\epsilon=100$ and $\epsilon=10$, the model performs well and accuracy is preserved. However, these values sit at the weaker end of what the differential privacy literature considers meaningful protection for sensitive health data. Context is critical for deciding an epsilon value. This has direct implications for how regulation should be designed. A single fixed epsilon threshold would be inappropriate across the range of contexts in which differential privacy is deployed. Higher epsilon values work well with large consumer datasets, but when applied to a healthcare dataset with a few thousand patients, the guarantees are much weaker (Near & Darais, 2022; Dyda et al., 2021). At $\epsilon=1$, the privacy guarantee is stronger and closer to what public health researchers consider an appropriate threshold for sensitive personal data. However, at this value the model loses most of its clinical utility. At $\epsilon=0.1$, the guarantee is stronger, but the model has no utility. The central finding is about the trade-off between privacy and utility. The epsilon values that provide meaningful privacy protection render the model clinically useless. The epsilon values that preserve clinical utility provide privacy guarantees that may be insufficient for the sensitivity of the data involved.

Under current ICO guidance, a firm can choose any of these values and be considered compliant. The findings also reveal something important about the nature of the problem. Firms are not necessarily choosing high epsilon values to minimise privacy. They are choosing them because the alternative, a model with high privacy guarantees, may not work. The privacy-utility trade-off is real, and in the absence of regulatory guidance, the commercial response is to resolve it in favour of utility. This is a structural feature of how the current framework operates, and it will persist as long as epsilon selection (and other technical choice) remains unregulated. This model is a proof of concept, and its findings should be interpreted with respect to its limitations. The data is synthetic, generated by Synthea rather than drawn from real patient records, and the federated architecture simulates hospital sites rather than representing a genuine cross-institutional deployment. The model only uses three features for training, whereas real clinical models are more complex. These limitations do not undermine the central finding, which is that the privacy-utility trade-off demonstrated here will look different with different datasets. Larger datasets, more features, and different levels of data sensitivity will shift where on the epsilon scale clinical utility is preserved and where it breaks down. This is precisely why regulatory guidance on epsilon selection cannot be one-size-fits-all, but also why the current absence of any guidance is inadequate.

Environment	Epsilon (ϵ)	Privacy level	Test accuracy	Sig. vs fed. baseline
Baselines				
Centralised baseline	—	None (ceiling)	 72.02%	$p = 0.009$
Federated (no DP)	—	Partial	 71.67%	—
Federated + differential privacy — all GDPR-compliant under current ICO guidance				
Federated + DP	100.0	Low	 71.94%	$p = 0.161$ (ns)
Federated + DP	10.0	Moderate	 71.63%	$p = 0.021$
Federated + DP	1.0	Strong	 64.12%	$p = 0.024$ ✓
Federated + DP	0.1	Maximum	 61.10%	$p < 0.001$ ✓

All accuracy figures evaluated on the same 2,252-patient held-out test set. Statistical significance tested using McNemar's test (Appendix D). Naive baseline (always predict negative) = 61.10%. All four DP configurations would be considered compliant under current ICO guidance.

Table 1: Experiment results

Part 5: Discussion

The gap identified in this paper is not unique to the UK. The US National Institute of Standards and Technology (NIST) published guidelines on differential privacy in March 2025 that illustrate what more substantive recommendations for epsilon look like (Near et al., 2025). NIST SP 800-226 explicitly flags that large epsilon values may not provide meaningful privacy, identifies $\epsilon=10$ or greater as potentially leaving outliers vulnerable to privacy leakage, and states that ϵ values below 1 are considered reasonable while values of 0.1 generally provide strong protection (Near et al., 2025). NIST also encourages publishing epsilon values to establish trust and accountability without creating additional privacy risk, which is a direct argument for disclosure requirements of the kind recommended in this paper. NIST stops short of mandating specific values, acknowledging that epsilon selection remains an open research question that depends on data context. But the contrast with the ICO's position is significant: NIST names risk thresholds, flags specific values as problematic, and calls for transparency. The ICO recommends differential privacy as a compliance tool without addressing any of these questions. The UK's pro-innovation regulatory posture creates an opportunity to develop guidance that goes further than the current approach.

Epsilon is one example of a broader challenge that this paper calls the parameterisation of legal principles. The same structural problem appears across other privacy-preserving techniques, many of which are directly used in federated learning and differential privacy deployments. Clipping thresholds, which determine how much any individual's data can influence a model, directly affect privacy outcomes and are set without regulatory guidance (Ponomareva et al., 2023). Noise mechanisms, such as the choice of Laplace or Gaussian noise, affect the distribution of privacy protection across subgroups, with recent research showing that

differential privacy can magnify existing biases against minority groups (Near et al., 2025). Model architecture choices, training duration, and data partitioning strategies all have privacy implications that current compliance frameworks cannot evaluate. In each case, the structure is the same: a legal principle requires a technical decision to give it practical meaning, that decision is made by an engineer, and the regulator has no prescribed standard against which to assess it. Epsilon is a useful entry point for addressing this problem because it is a single, quantifiable parameter with a measurable relationship to privacy risk. Demonstrating that regulatory intervention is both feasible and productive for epsilon creates a template for addressing the wider class of technical discretion problems that GDPR has left unresolved.

A final consideration is that the technical foundations of differential privacy are evolving. The mathematical guarantees provided by a given epsilon value depend on the newest and most powerful inference attack methods. New attack methods can effectively weaken the protection offered by previously published epsilon values without any change to the deployment itself. This creates a particular challenge for regulation. Once a model is trained with a given epsilon, retraining is not trivial: it can take months and create substantial computational cost, particularly for large-scale deployments. A regulatory framework that fixes epsilon thresholds too rigidly risks placing firms in an impossible position, where compliance at the time of deployment becomes non-compliance months later. Governing bodies must commit to continuous monitoring of the technical landscape, which takes resources to perform well.

Part 6: Policy Options

Option	Time horizon	Description
Mandatory epsilon disclosure for federated learning deployments	Short term	Requires firms to include their epsilon value and a brief justification in DPIAs for federated learning deployments processing special category data.
Proactive DPIA Submission Requirement for FL Deployments	Medium term	Firms must submit completed DPIAs to the ICO at least 60 days before deployment, giving the regulator a window to raise formal objections.
A federated learning pilot programme within the ICO regulatory sandbox	Medium term	A dedicated FL+DP pilot programme within the ICO sandbox, giving participating firms regulatory clarity in exchange for transparency about their implementation choices.
FL+DP as a preferred transfer mechanism with given epsilon ranges	Medium to long term	Formal ICO recognition of federated learning with differential privacy as presumptively compliant under UK GDPR, conditional on meeting a specified epsilon disclosure standard.

ICO privacy engineering unit	Long term	A specialist team of data scientists and machine learning engineers embedded within the ICO to evaluate technical privacy parameters and support oversight.
------------------------------	-----------	---

Table 2: Policy options

Option 1: Mandatory epsilon disclosure for federated learning deployments

The ICO should update its DPIA guidance to require mandatory disclosure of the epsilon value for federated learning deployments processing special category data. This requirement would apply under Article 9 of the UK GDPR, which affords the strictest protections to sensitive data including health records, biometric data, and data concerning mental health or sexual orientation (UK GDPR, Article 9). The case for epsilon disclosure has academic precedent: Dwork et al. (2019) argue that organisations deploying differential privacy should publish their epsilon values as a matter of accountability, and that doing so is feasible. This builds on NIST SP 800-226, which has already identified epsilon disclosure as best practice for trust and accountability (Near et al., 2025). The firm would need to include the epsilon value selected and a brief justification for why that value was considered appropriate given the data type and deployment context. The firm would also disclose the size of the dataset on which the model is trained.

Advantages

This recommendation is achievable immediately. It requires a revision to ICO DPIA guidance, which the ICO can issue under its existing powers. The administrative burden on both the ICO and firms is low. The DPIA submission process is already in place, and epsilon is a single number that any team running a federated learning system will easily be able to communicate. The justification required is a brief narrative explanation that engineers produce routinely for internal documentation. Over time, the ICO can accumulate a set of implementation data that can help determine long-term technical recommendations in this area. Disclosure also creates conditions for productive engagement between the ICO and industry on this topic: firms have nothing to lose from disclosure. Dwork et al. (2019) note that firms have little incentive to disclose epsilon values voluntarily, and research confirms that despite best practice guidance recommending disclosure such as from the NIST, epsilon values remain seldom published in practice. This suggests that guidance alone is insufficient to produce meaningful transparency.

Limitations

This recommendation creates visibility but does not address the underlying problem. A firm can still disclose any epsilon value and remain fully compliant, regardless of the privacy protection provided. Firms may also resist disclosure on the grounds that epsilon values reveal proprietary information about their model architecture or data practices, giving competitors confidential information. NIST SP 800-226 explicitly states that publishing epsilon values creates no additional privacy risk for companies (Near et al., 2025). However, it is likely to be raised as an objection and the ICO would need to address it proactively.

Option 2: Proactive DPIA Submission Requirement for FL Deployments

Firms deploying federated learning systems that process special category data would be required to submit their completed DPIA, including the technical epsilon, to the ICO at least 60 days before deployment. Firms may proceed with deployments unless the ICO raises a formal objection within that window. This is a notification requirement, rather than a mandatory approval requirement.

Advantages

This option converts the DPIA from a retrospective document into real oversight, while also giving firms freedom to deploy. Firms that have configured their FL deployments appropriately are not impacted by the 60-day notification window, other than the waiting period. It gives the ICO flexibility to add enforcement, while not having companies wait for deployments.

Limitations

Larger firms with established legal and compliance teams will be able to manage the 60-day window without difficulty. For early-stage companies and startups, a mandatory 60-day pre-deployment delay may be impossible to adhere to. The burden falls on smaller firms and startups, for whom a two-month delay before deployment can miss a market window or exhaust funding. This matters because the UK has explicitly positioned itself as a pro-innovation jurisdiction that wants to be competitive for AI startups (DSIT, 2023). A blanket notification requirement creates a regulatory friction that will severely impact the startup space. There is also a risk that without more resources, ICO lacks the capacity to review meaningfully within the window, making this of similar effectiveness as option 1.

Option 3: A federated learning pilot programme within the ICO regulatory sandbox

The ICO should formally designate federated learning with differential privacy as a priority focus area within its sandbox. A dedicated cohort of technology firms would be recruited to deploy FL+DP systems for a defined pilot period, with ICO staff embedded as observers rather than enforcers. Participation would be voluntary and in exchange for transparency about implementation choices, including their epsilon values and the justification for them, participating organisations would receive a statement of regulatory approval on exit. A structured pilot programme would give the ICO a dataset of implementation choices, alongside their context and outcomes. This will help build an evidence base for future epsilon regulation.

A regulatory sandbox is a formal programme in which a regulator permits some organisations to trial a technology or business model under close supervision, with modified or relaxed compliance requirements during the testing period. The objective is not to lower standards permanently, but to collect evidence about how a technology behaves in practice before standards are set. The FCA used this model in 2016 for financial technology, and firms that completed the sandbox process had increased capital, because sandbox participation signalled regulatory credibility to investors (Cornelli et al., 2020). The model has since been adopted across dozens of jurisdictions and sectors. The ICO already operates its own regulatory sandbox for GDPR data protection (Information Commissioner's Office, n.d.).

Advantages

The sandbox model is mutually beneficial to regulators and industry. Firms without regulatory certainty can use sandbox participation to reduce the ambiguity they face. As discussed in Part 2, regulatory ambiguity has already caused firms including Google and Meta to delay or withdraw products from European markets entirely. For firms facing this kind of uncertainty, sandbox participation offers a concrete path to regulatory clarity without waiting for formal guidance to be developed. This puts firms ahead of competitors who remain uncertain about compliance, potentially opening new markets and business opportunities that were previously inaccessible due to that uncertainty. This supports innovation as well as giving the regulator technical context that they may not have otherwise.

Limitations

Building a meaningful evidence base through sandbox participation could take several years before actionable findings are created. This will not address the short-term accountability gap. The use of real special category data presents a design problem: sensitive data cannot be fully anonymised while also testing the conditions of epsilon choice in the sandbox. It would be difficult to use real firms and real use cases while also having a full guarantee of data protection. The statement of regulatory approval on exit risks creating unfair advantages for firms that participate. This may benefit larger, more established firms with the resources to engage with the sandbox process over smaller firms that do not.

Option 4: ICO privacy engineering unit

This option establishes an ICO Privacy Engineering Unit with data scientists, machine learning engineers, and computer scientists with the specific goal of evaluating privacy-preserving technology. The direct precedent is the FCA, which has embedded data scientists and quantitative analysts into its supervision teams to address the fundamental problem that regulators cannot meaningfully oversee what they do not understand (Financial Conduct Authority, 2025). The ICO's ICO25 strategic plan acknowledges the need for greater technical expertise, but it has not been implemented yet (ICO, 2022). The unit would review the technical DPIA disclosures, run and interpret the sandbox pilot programme, and provide expert input into enforcement cases where technical parameters are contested.

Advantages

Without technical expertise, the ICO cannot meaningfully interpret the epsilon disclosures or sandbox findings that the earlier recommendations generate. Someone with technical expertise needs to be making these decisions, and these personnel are not in place today. This option also has direct precedent in other UK regulatory bodies such as the FCA, and the Competition and Markets Authority's Data, Technology and Analytics unit (Competition and Markets Authority, 2019). These demonstrate that technical capacity can be embedded within existing regulators.

Limitations

Recruiting and retaining personnel with the necessary machine learning expertise and regulatory interest may be difficult. The private sector can offer substantially higher salaries

than a public body. The FCA managed this through the prestige of regulatory roles and through structured graduate programmes that build technical capacity from within rather than competing for experienced hires. The ICO would need a similar approach, but building meaningful capability could take years. Even with technical expertise, the engineering unit may need to make judgement calls about compliance at a granular level at each firm, depending on the technical implementation details. Investing in the implementation details of each firm's deployments may not be possible at scale.

Option 5: FL+DP as a preferred transfer mechanism

This option formally recognises federated learning with differential privacy as a presumptively compliant approach to processing special category data under Article 9 of the UK GDPR, conditional on meeting a specified disclosure standard. If data type, epsilon value, dataset size, and context fall within the ranges found to reach anonymisation from the sandbox findings, then firms have assurances that they are compliant. To begin, the disclosure standard can be a range determined from current literature, such as $0 < \epsilon < 10$.

Advantages

As discussed earlier, ambiguous law is slowing down innovation because firms do not know what they are allowed to deploy. By developing the standard by which FL/DP is compliant, firms can feel confident that their deployments will not raise regulatory scrutiny. This approach leaves flexibility to update the range for more certain privacy guarantees while also giving firms the go-ahead to use FL/DP in the meantime. For firms that have delayed or withdrawn products from European markets due to regulatory uncertainty, a clear compliance pathway under UK law makes the UK a meaningfully more attractive jurisdiction for AI deployment.

Limitations

Technical standards for compliance are constantly changing, and the ICO would need to commit to regular reviews of the technical conditions as model architectures, dataset sizes, and published attacks on differential privacy change. This is a non-trivial amount of work and could take large investment to maintain. As the ranges are updated, companies would need to update their deployments, which could lead to industry pushback and create workload that would negatively impact smaller firms. Also, the beginning range would be decided without full investigation of epsilon values via sandbox or data collection. This risks having an initial range without proper privacy guarantees.

Part 7: Policy Recommendations & Implementation

This paper recommends three complementary policy options. Together, they create a framework where epsilon selection moves from an invisible technical choice to a governable policy decision and create a precedent for other areas of technical parameterisation to be governed in a way that reduces ambiguity for businesses and increases governability for governments.

Recommendation 1: Mandatory Epsilon Disclosure

The ICO has existing powers under UK GDPR Article 35 to issue guidance on DPIA requirements, so this recommendation does not require new legislation. In the short term (3-6 months), the ICO can issue new guidance indicating that DPIAs must record and justify epsilon values where FL+DP is used. DPIAs are only completed when new data is added to processing activities, so the new requirement will be phased in as data processing changes. To better diversify this guidance through different channels, DSIT can add epsilon disclosure information to their AI playbook on responsible AI deployment in government. This would increase visibility and normalise epsilon disclosure among large processors of sensitive personal data in government, such as the NHS.

Recommendation 2: Regulatory Sandbox

The ICO sandbox is already operational and currently accepts applications from organisations wishing to develop innovative uses of personal data in a regulatory environment. In the next 6 months, the ICO will create an application for organisations specifically deploying federated learning and differential privacy. Participating organisations would work with ICO technical staff to document their epsilon selection, test different epsilon selections within different contexts, and investigate the impact of data size, Gaussian noise, and clipping on the results. Within one year, the sandbox should have the first set of results. The goal is to complete testing with the first organisation within the first year, but over three years, ramp up resources to complete testing with 5-7 organisations. To build the technical capacity required to run this programme, the ICO will hire and source technical staff incrementally as the programme scales. As the number of sandbox participants grows from the first organisation in year one to 5-7 organisations over three years, staffing will expand accordingly, ensuring capacity is built at a pace matched to demand.

Recommendation 3: Preferred Transfer Mechanism

In the first 6-12 months, the ICO would draw on mandatory disclosure data from Recommendation 1 to research epsilon values across sectors and establish a preliminary acceptable range. The ICO would publish these ranges as a preferred mechanism for Article 25 of UK GDPR. If firms deploy FL+DP within the range, they have clear compliance. This reduces ambiguity in the short term without introducing new risk, because currently there is no acceptable range. Over the next three years, the results from the sandbox would be integrated to come up with a range that is backed by evidence and investigations across a variety of contexts.

Alternative opinion:

It should be noted that this type of technical and legal issue is a genuinely complex problem to which there are no easy solutions. The recommendations set out in this brief are not a complete fix, but are options that can guide policymakers toward greater accountability while the evidence base develops. These options reduce the ambiguity around epsilon selection to promote innovation, but they do not resolve the underlying tension between privacy and model utility depending on context. Privacy is important, but it must be balanced against the cost to innovation and usability, and different stakeholders may weigh that balance in different ways.

Part 8: Conclusion

This paper examined the gap in the parameterisation of legal principles, where abstract obligations under GDPR are translated into concrete technical values without regulatory oversight. GDPR's technology-neutral design was a deliberate choice, but it has left firms and regulators with ambiguity about compliance. Firms are asked to make consequential privacy decisions without standards for guidance, and regulators are asked to oversee technologies for which they do not have expertise. Using epsilon as a focused case study, the federated learning model developed for this paper makes the trade-off visible. At the epsilon values where the model retains clinical utility, the privacy guarantee for sensitive health data is weak. At the values where privacy protection is meaningful, the model loses most of its diagnostic value. This is a genuinely difficult trade-off, and resolving it well will require flexibility, technical capacity, and sustained engagement from the ICO.

The three recommendations proposed in this paper: mandatory epsilon disclosure, a regulatory sandbox, and a preferred mechanism designation for compliant FL+DP deployments, are designed to close that gap incrementally in a way that supports innovation. Together, these recommendations will move epsilon selection from an invisible technical choice into a governable policy decision. These recommendations will also establish a template that can be extended to the wider class of technical discretion problems GDPR has left unresolved.

References

- Abadi, M., Chu, A., Goodfellow, I., McMahan, H. B., Mironov, I., Talwar, K., & Zhang, L. (2016). Deep learning with differential privacy. *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, 308–318. <https://doi.org/10.1145/2976749.2978318>
- Ada Lovelace Institute & Alan Turing Institute. (2025). *How do people feel about AI? Understanding public attitudes to AI: Second survey*. <https://attitudestoai.uk/>
- American Diabetes Association Professional Practice Committee. (2026). 2. Diagnosis and classification of diabetes: Standards of care in diabetes—2026. *Diabetes Care*, 49(Suppl. 1), S27–S49. <https://doi.org/10.2337/dc26-S002>
- Apple Differential Privacy Team. (2017). Learning with privacy at scale. *Apple Machine Learning Research*. <https://machinelearning.apple.com/research/learning-with-privacy-at-scale>
- Brown, R., Sillence, E., Coventry, L., Simpson, E., Gibbs, J., Tariq, S., Durrant, A. C., & Lloyd, K. (2022). Understanding the attitudes and experiences of people living with potentially stigmatised long-term health conditions with respect to collecting and sharing health and lifestyle data. *DIGITAL HEALTH*, 8, 205520762210897. <https://doi.org/10.1177/20552076221089798>
- Calabrese, S. (2026). EU Regulation on Transparency and Targeting of Political Advertising: What Impact for CSOs? European Partnership for Democracy. <https://epd.eu/news-publications/eu-regulation-on-transparency-and-targeting-of-political-advertising-what-impact-for-csos/>
- Calvino, G., Peconi, C., Strafella, C., Trastulli, G., Megalizzi, D., Andreucci, S., Cascella, R., Caltagirone, C., Zampatti, S., & Giardina, E. (2024). Federated Learning: Breaking Down Barriers in Global Genomic Research. *Genes*, 15(12), 1650. <https://doi.org/10.3390/genes15121650>
- Cancer Image Europe. (n.d.). Building a Data-Driven Future for Cancer Care. Retrieved May 6, 2026, from <https://cancerimage.eu>
- Centers for Disease Control and Prevention. (2024). National Diabetes Statistics Report. <https://www.cdc.gov/diabetes/php/data-research/index.html>
- Competition and Markets Authority. (2019). *The CMA DaTA unit*. <https://competitionandmarkets.blog.gov.uk/2019/05/28/the-cma-data-unit-were-growing/>

- Cornelli, G., Frost, J., Gambacorta, L., & Radde, S. (2020). *Regulatory sandboxes and fintech funding: Evidence from the UK* (BIS Working Paper No. 901). Bank for International Settlements. <https://www.bis.org/publ/work901.htm>
- Covington Privacy Team. (2025). European commission proposes revisions to GDPR and other digital rules under digital omnibus package. *Covington*. <https://www.insideprivacy.com/eu-data-protection/european-commission-proposes-revisions-to-gdpr-and-other-digital-rules-under-digital-omnibus-package/>
- Department for Science, Innovation and Technology. (2023). AI regulation: a pro-innovation approach. *Gov.UK*. <https://www.gov.uk/government/publications/ai-regulation-a-pro-innovation-approach>
- Department for Science, Innovation and Technology. (2025). Data (Use and Access) Act 2025. *Gov.UK*. <https://www.gov.uk/government/collections/data-use-and-access-act-2025>
- Dietterich, T. G. (1998). Approximate Statistical Tests for Comparing Supervised Classification Learning Algorithms. *Neural Computation*, 10(7), 1895–1923. <https://doi.org/10.1162/089976698300017197>
- Directorate-General for Communication. (2024). AI Act enters into force. European Commission. https://commission.europa.eu/news-and-media/news/ai-act-enters-force-2024-08-01_en
- Dwork, C., Kohli, N., & Mulligan, D. (2019). Differential Privacy in Practice: Expose your Epsilons! *Journal of Privacy and Confidentiality*, 9(2). <https://doi.org/10.29012/jpc.689>
- Dwork, C., McSherry, F., Nissim, K., & Smith, A. (2006). Calibrating Noise to Sensitivity in Private Data Analysis (pp. 265–284). https://doi.org/10.1007/11681878_14
- Dyda, A., Purcell, M., Curtis, S., Field, E., Pillai, P., Ricardo, K., Weng, H., Moore, J. C., Hewett, M., Williams, G., & Lau, C. L. (2021). Differential privacy for public health data: An innovative tool to optimize information sharing while protecting data confidentiality. *Patterns*, 2(12), 100366. <https://doi.org/10.1016/j.patter.2021.100366>
- European Commission. (2025). Digital Package. European Commission. <https://digital-strategy.ec.europa.eu/en/faqs/digital-package>
- Financial Conduct Authority. (2025). *Harnessing AI and technology to deliver the FCA's 2025 strategic priorities*. <https://www.fca.org.uk/news/speeches/harnessing-ai-and-technology>

- Fried, I. (2024). Scoop: Meta won't offer future multimodal AI models in EU. *Axios*. <https://www.axios.com/2024/07/17/meta-future-multimodal-ai-models-eu>
- Hawkins, N. (2025). Brussels to soften AI rules in the face of big tech backlash. *Capacity*. <https://capacityglobal.com/news/brussels-to-softens-ai-rules-in-the-face-of-big-tech-backlash/>
- Hsu, J., Gaboardi, M., Haeberlen, A., Khanna, S., Narayan, A., Pierce, B. C., & Roth, A. (2014). Differential privacy: An economic method for choosing epsilon. *Proceedings of the 2014 IEEE 27th Computer Security Foundations Symposium (CSF 2014)*, 398–410. <https://doi.org/10.1109/csf.2014.35>
- IEEE Digital Privacy. (n.d.). Global Adoption of Data Privacy Laws and Regulations. *IEEE Digital Privacy*. Retrieved May 18, 2026, from <https://digitalprivacy.ieee.org/publications/topics/global-adoption-of-data-privacy-laws-and-regulations/>
- Information Commissioner's Office. (n.d.). *NHS Digital regulatory sandbox final report*. <https://ico.org.uk/media2/migrated/2618905/nhs-digital-regulatory-sandbox-final-report.pdf>
- Information Commissioner's Office. (2022). *ICO25 strategic plan*. <https://ico.org.uk/about-the-ico/our-information/our-strategies-and-plans/ico25-plan/>
- Information Commissioner's Office. (2023). Guidance on privacy enhancing technologies (PETs). <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-sharing/privacy-enhancing-technologies/>
- Information Commissioner's Office. (2025). Preventing harm, promoting trust: our AI and biometrics strategy. <https://ico.org.uk/about-the-ico/our-information/our-strategies-and-plans/artificial-intelligence-and-biometrics-strategy/>
- Jordan, M. I., & Mitchell, T. M. (2015). Machine learning: Trends, perspectives, and prospects. *Science*, 349(6245), 255–260. <https://doi.org/10.1126/science.aaa8415>
- Kaissis, G., Ziller, A., Passerat-Palmbach, J., Ryffel, T., Usynin, D., Trask, A., Lima, I., Mancuso, J., Jungmann, F., Steinborn, M.-M., Saleh, A., Makowski, M., Rueckert, D., & Braren, R. (2021). End-to-end privacy preserving deep learning on multi-institutional medical imaging. *Nature Machine Intelligence*, 3(6), 473–484. <https://doi.org/10.1038/s42256-021-00337-8>
- Kerasidou, A., & Kerasidou, C. (2023). Data-driven research and healthcare: public trust, data governance and the NHS. *BMC Medical Ethics*, 24, 52. <https://doi.org/10.1186/s12910-023-00922-z>

- Kortis, A., Mischke, J., Baroudy, K., Hieronimus, S., Johansson, S., & Olanrewaju, T. (2026). Transforming Europe: Bold moves to lift a continent. McKinsey & Company. <https://www.mckinsey.com/featured-insights/insights-on-europe/transforming-europe-bold-moves-to-lift-a-continent>
- Mathur, A., Acar, G., Friedman, M. J., Lucherini, E., Mayer, J., Chetty, M., & Narayanan, A. (2019). Dark Patterns at Scale. *Proceedings of the ACM on Human-Computer Interaction*, 3(CSCW), 1–32. <https://doi.org/10.1145/3359183>
- McMahan, B., Moore, E., Ramage, D., Hampson, S., B. Agüera y Arcas B. (2017). Communication-Efficient Learning of Deep Networks from Decentralized Data. *Proceedings of the 20th International Conference on Artificial Intelligence and Statistics*, 1273–1282. <https://proceedings.mlr.press/v54/mcmahan17a.html>
- McMahan, H. B., Andrew, G., Erlingsson, U., Chien, S., Mironov, I., Papernot, N., & Kairouz, P. (2018). A general approach to adding differential privacy to iterative training procedures (arXiv:1812.06210). arXiv. <https://arxiv.org/abs/1812.06210>
- Narayanan, A., & Felten, E. W. (2014). *No silver bullet: De-identification still doesn't work* [White paper]. <https://www.cs.princeton.edu/~arvindn/publications/no-silver-bullet-de-identification.pdf>
- Near, J., & Darais, D. (2022). Differential Privacy: Future Work & Open Challenges. *NIST Cybersecurity Insights Blog*. <https://www.nist.gov/blogs/cybersecurity-insights/differential-privacy-future-work-open-challenges>
- Near, J. P., Darais, D., Lefkovitz, N., & Howarth, G. S. (2025). *Guidelines for evaluating differential privacy guarantees*. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-226>
- NHS England. (n.d.). NHS Federated Data Platform. Retrieved May 6, 2026, from <https://www.england.nhs.uk/digitaltechnology/nhs-federated-data-platform/>
- Nouwens, M., Liccardi, I., Veale, M., Karger, D., & Kagal, L. (2020). Dark Patterns after the GDPR: Scraping Consent Pop-ups and Demonstrating their Influence. *Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems*, 1–13. <https://doi.org/10.1145/3313831.3376321>
- Oldenhof, M., Ács, G., Pejó, B., Schuffenhauer, A., Holway, N., Sturm, N., Dieckmann, A., Fortmeier, O., Boniface, E., Mayer, C., Gohier, A., Schmidtke, P., Niwayama, R., Kopecky, D., Mervin, L., Rathi, P. C., Friedrich, L., Formanek, A., Antal, P., ... Galtier, M. (2023). Industry-Scale Orchestrated Federated Learning for Drug Discovery. *Proceedings of the AAAI Conference on Artificial Intelligence*, 37(13), 15576–15584. <https://doi.org/10.1609/aaai.v37i13.26847>

- Pettigrew, L. M., Petersen, I., Mays, N., & Cromwell, D. (2024). The changing shape of English general practice: a retrospective longitudinal study using national datasets describing trends in organisational structure, workforce and recorded appointments. *BMJ Open*, 14(8), e081535. <https://doi.org/10.1136/bmjopen-2023-081535>
- Ponomareva, N., Hazimeh, H., Kurakin, A., Xu, Z., Denison, C., McMahan, H. B., Vassilvitskii, S., Chien, S., & Thakurta, A. G. (2023). How to DP-fy ML: A Practical Guide to Machine Learning with Differential Privacy. *Journal of Artificial Intelligence Research*, 77, 1113–1201. <https://doi.org/10.1613/jair.1.14649>
- Rajpurkar, P., Chen, E., Banerjee, O., & Topol, E. J. (2022). AI in health and medicine. *Nature Medicine*, 28, 31–38. <https://doi.org/10.1038/s41591-021-01614-0>
- Rieke, N., Hancox, J., Li, W., Milletari, F., Roth, H. R., Albarqouni, S., Bakas, S., Galtier, M. N., Landman, B. A., Maier-Hein, K., Ourselin, S., Sheller, M., Summers, R. M., Trask, A., Xu, D., Baust, M., & Cardoso, M. J. (2020). The future of digital health with federated learning. *Npj Digital Medicine*, 3(1), 119. <https://doi.org/10.1038/s41746-020-00323-1>
- Sheehan, M. (2023). *China's AI regulations and how they get made*. Carnegie Endowment for International Peace. <https://carnegieendowment.org/research/2023/07/chinas-ai-regulations-and-how-they-get-made>
- Sweeney, L. (2002). k-Anonymity: A Model for Protecting Privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*, 10(05), 557–570. <https://doi.org/10.1142/S0218488502001648>
- Tang, J., Korolova, A., Bai, X., Wang, X., & Wang, X. (2017). *Privacy loss in Apple's implementation of differential privacy on macOS 10.12* (arXiv:1709.02753). arXiv. <https://arxiv.org/abs/1709.02753>
- ten Eikelder, M. (2026). GDPR Enforcement Trends: €7.1 Billion in Fines and Rising. *Kiteworks*. <https://www.kiteworks.com/gdpr-compliance/gdpr-fines-data-privacy-enforcement-2026/>
- Truong, N., Sun, K., Wang, S., Guitton, F., & Guo, Y. K. (2021). Privacy preservation in federated learning: An insightful survey from the GDPR perspective. *Computers & Security*, 110, 102402. <https://doi.org/10.1016/j.cose.2021.102402>
- UK General Data Protection Regulation (UK GDPR). (2018). <https://www.legislation.gov.uk/eur/2016/679/contents>.
- Walonoski, J., Kramer, M., Nichols, J., Quina, A., Moesel, C., Hall, D., Duffett, C., Dube, K., Gallagher, T., & McLachlan, S. (2018). Synthea: An approach, method, and software mechanism for generating synthetic patients and the synthetic electronic health care

record. *Journal of the American Medical Informatics Association*, 25(3), 230–238. <https://doi.org/10.1093/jamia/ocx079>

Zhu, L., Liu, Z., & Han, S. (2019). Deep leakage from gradients. In *Advances in Neural Information Processing Systems 32 (NeurIPS 2019)*. <https://papers.nips.cc/paper/9617-deep-leakage-from-gradients>

Appendix A: Model Design

Part 1: Environment Virtualisation and Version Control

To ensure reproducibility, the model was built and executed inside a Docker container running Ubuntu Linux. Containerisation was necessary because the core libraries, TensorFlow Federated (TFF) and TensorFlow Privacy, have strict interdependencies and are sensitive to Python version conflicts. By specifying exact library versions in the Dockerfile, any researcher can recreate the precise computational environment used to produce the results in this paper. Key pinned versions include TensorFlow, TensorFlow Federated, TensorFlow Privacy, and JAX. All source code, the Dockerfile, and version specifications are stored in a public GitHub repository.

Part 2: TensorFlow Federated

Several libraries support federated learning and differential privacy, including Flower, PySyft, and NVIDIA FLARE. TensorFlow Federated (TFF) was selected primarily for its native integration with TensorFlow Privacy, which provides the tools necessary to add differential privacy noise and calculate epsilon values. This integration allowed the three core libraries, TensorFlow (model training), TensorFlow Federated (multi-client simulation), and TensorFlow Privacy (differential privacy noise and epsilon tracking), to model federated learning with differential privacy (McMahan et al., 2018).

Part 3: Data Generation

Synthea was used to generate the data for the model. Synthea is an open-source synthetic patient generator that simulates the entire medical history of non-existent patients. Unlike “anonymised” data, which is real data with the identifying information removed, Synthea is generated synthetically. There is zero risk of re-identification because the individuals in the data set do not exist (Walonoski et al., 2018). Synthea generates data by modelling patients using real-world distributions. Synthea starts by creating a population based on real-world United States census data. This ensures race, age, and gender are distributed as close to reality as possible. Synthea then simulates health events based on clinical guidelines and public health statistics to show a patient's progress through medical events. Synthea uses probability data to decide what happens to each patient based on treatment and outcome (Walonoski et al., 2018). Synthea provides statistical realism without a privacy liability for this paper. While the patients are not real, the clinical pathways are based on accurate medical statistics. This allows the paper to focus on the technical federated learning model without compromising patient confidentiality (Walonoski et al., 2018).

Part 4: Data Selection

To accurately model the policy implications of federated learning, health data was chosen because it is a type of personally identifiable information (PII) that is highly sensitive, strictly regulated, and historically difficult to share for research purposes. To build effective diagnostic models, large health datasets must be used. Federated learning is often cited as a solution to this problem because it allows hospitals and institutions to collaborate without exchanging raw patient records (Calvino et al., 2024).

Once the health data was compiled, pre-diabetes was chosen as my specific use case for several reasons:

- Approximately 38% of the population has pre-diabetes, but it is often undiagnosed (Centers for Disease Control and Prevention, 2024)
- Diagnosis can be predicted through BMI, age, and gender
- Official diagnosis can be confirmed through a blood test called HbA1c (American Diabetes Association Professional Practice Committee, 2026)

This combination allows us to train a machine learning model to "learn" what BMI, age, and gender values could predict prediabetes.

Part 5: Sample size

A sample size of 11,257 was chosen because the sample size must be large enough to allow the model to learn meaningful patterns, but small enough to demonstrate the constraints of how much data an individual healthcare entity has available. This reflects a deliberate design choice to test federated learning under realistic conditions. GP practices in England hold an average of approximately 9,700 registered patients (Pettigrew et al., 2024), meaning each simulated clinic in this model represents roughly one fifth of a typical practice list. This is consistent with the scale of data that a single institution might have with all necessary data points for a research study like this. The full pre-processed dataset of 11,257 patients was split 80/20 into a training set of 9,005 patients and a test set of 2,252 patients, leaving a per-site allocation of approximately 1,801 training patients.

Part 6: Data Census and Condition Selection

Before selecting a diagnostic target, a data census was conducted across the full Synthea output to identify the prevalence of different conditions. The census script (`data_census.py`) loaded the raw Synthea conditions and patient CSV files, counted the number of distinct patients associated with each condition description, and computed a prevalence percentage across the total patient population. The top thirty conditions by patient count were examined. Prediabetes was selected as the target condition. It appeared at a prevalence of approximately 38% in the generated cohort, providing enough positive cases to train a meaningful classifier at the chosen sample size. It is clinically predictable from three readily available features: BMI, age, and biological sex, and its diagnosis is formally established through a quantitative blood test (HbA1c), which means the ground-truth label is well-defined and commonly tested for (Centers for Disease Control and Prevention, 2024).

Part 7: Data Preprocessing and Hospital Partitioning

Once the condition was selected, the raw Synthea output was transformed into a model-ready dataset by joining three Synthea source files: `patients.csv`, which contains demographic information including date of birth and biological sex; `conditions.csv`, which lists all recorded diagnoses per patient; and `observations.csv`, which records clinical measurements over time. A binary target label was created by scanning each patient's condition history for any entry matching "prediabetes". Patients with no matching condition were assigned a negative label. The most recent Body Mass Index observation for each patient was extracted from the

observations file, and age was derived from the patient's recorded date of birth. Biological sex was encoded as a binary integer (0 for female, 1 for male). Patients with no recorded BMI measurement were excluded from the dataset, as BMI is a required feature for the model. Patient labels were assigned based on recorded diagnoses in conditions.csv rather than underlying physiological state. Synthea's patients, like real-life patients, may have prediabetes without a formal diagnosis. This mirrors the labelling constraints of real clinical datasets, where undiagnosed conditions are invisible to machine learning models.

Feature normalisation is a technical requirement for differential privacy (Abadi et al., 2016). Normalising all features to the range [0, 1] ensures that adding noise is applied uniformly. BMI was normalised using a fixed clinical range of 15 to 45 (the plausible range from severe underweight to morbid obesity). Age was normalised against the range of 0 to 100 years. Biological sex was already encoded as a binary 0 or 1.

Following preprocessing, the dataset was partitioned into five separate subsets to simulate a federated hospital or GP network (partition.py). The partition was conducted by first randomly shuffling the full dataset using a fixed random seed to ensure that the distribution of patient characteristics and label prevalence was approximately equal across all five simulated hospitals. The shuffled dataset was then divided into five subsets of roughly 1,801 patients. Each subset was assigned a clinic identifier. This equal and random partition creates an "IID" (independently and identically distributed) training set, which represents the most favourable case for federated learning accuracy.

Part 8: Training Design

The same neural network architecture was used across all three experimental environments: centralised baseline, federated baseline, and federated with differential privacy. This ensures that any differences in accuracy are attributable to the training environment rather than the model itself.

The model is a small neural network built using Keras with three layers. It takes BMI, age, and biological sex as inputs and produces a probability that the patient is pre-diabetic. A result above 50% is classified as positive. The architecture was kept deliberately simple because with only three input features, a more complex model would likely not perform better and would make it harder to isolate the effect of differential privacy on accuracy. Standard training settings were used throughout, and the same architecture was used identically across all three environments.

Centralised Baseline (baseline_training.py): The full pre-processed training dataset of 9,005 patients was used to train a model for 20 epochs. Accuracy was evaluated exclusively on the test set, which the model never encountered during training. The centralised baseline represents the theoretical performance ceiling for this model. All 9,005 training patients were pooled into a single dataset and the model was trained on them together, as if every hospital had shared its raw patient records with a central server. This is the approach that data

protection law is designed to prevent. Its 72.02% accuracy serves as the benchmark against which the federated and differentially private models are compared.

Federated Baseline (federated_baseline.py): The federated baseline tests whether the model can achieve comparable accuracy without any raw data leaving the simulated hospital sites. The 9,005 training patients were divided equally across five clinics of approximately 1,801 patients each. Each clinic trained the model locally on its own data, and only the model updates, not the patient data, were shared with a central server for aggregation. This process repeated for 20 rounds. The federated baseline achieved 71.67% accuracy on the same test set, a difference of less than half a percentage point from the centralised baseline.

Federated with Differential Privacy (federated_dp.py): The federated differential privacy scenario tests the same federated setup with differential privacy added at four different strength levels. Differential privacy is a mathematical framework that protects individual privacy by adding carefully calibrated random noise to model updates, making it more difficult to determine whether any individual patient's data was included in the training set. Epsilon (ϵ) is the parameter that controls how much privacy protection is applied. A lower epsilon means stronger privacy but more noise added to the model updates, which degrades accuracy. Four values were tested: $\epsilon=100$ (low privacy), $\epsilon=10$ (moderate privacy), $\epsilon=1$ (strong privacy), and $\epsilon=0.1$ (maximum privacy).

The results show a clear threshold effect. At $\epsilon=100$ and $\epsilon=10$, accuracy remained close to the federated baseline at 71.94% and 71.63% respectively, suggesting that moderate privacy guarantees impose negligible accuracy cost at this dataset size. At $\epsilon=1$, accuracy fell sharply to 64.12%, a drop of more than seven percentage points from the federated baseline. At $\epsilon=0.1$, accuracy fell further to 61.10%, matching the naive baseline of simply predicting that no patient has prediabetes. This suggests that at maximum privacy the model was unable to extract meaningful signal from the data.

Code Availability: The complete technical environment, including the Docker configuration and the TensorFlow Federated model logic, is available on GitHub at: <https://github.com/alyssajotice/tff-poc>.

Appendix B: Results Table

Environment	Epsilon (ϵ)	Privacy level	Test accuracy
Baselines			
Centralized baseline	—	None	72.02%
Federated (no DP)	—	Partial	71.67%
Federated + differential privacy			
Federated + DP	100.0	Low	71.94%
Federated + DP	10.0	Moderate	71.63%
Federated + DP	1.0	Strong	64.12%
Federated + DP	0.1	Maximum	61.10%

Figure 2: Results

Appendix C: Confidence Intervals

Environment	ϵ	Privacy	Accuracy	95% confidence interval
BASELINES				
Centralized	—	None	72.02%	[70.2%, 73.9%]
Federated (no DP)	—	Partial	71.67%	[69.8%, 73.5%]
FEDERATED + DIFFERENTIAL PRIVACY				
Federated + DP	100.0	Low	71.94%	[70.1%, 73.8%]
Federated + DP	10.0	Moderate	71.63%	[69.8%, 73.5%]
Federated + DP	1.0	Strong	64.12%	[62.1%, 66.1%]
Federated + DP	0.1	Maximum	61.10%	[59.1%, 63.1%]

Figure 3: 95% Wilson score confidence intervals, $n=2,252$ test patients. Naive baseline = always predict negative (no prediabetes). Non-overlapping intervals indicate a statistically significant difference in accuracy at the 95% confidence level

Comparison	Intervals overlap?	Significant?
Naive baseline vs $\epsilon=1$	No	Yes
Naive baseline vs $\epsilon=0.1$	Yes	No
Centralized vs federated baseline	Yes	No
Federated baseline vs $\epsilon=100$	Yes	No
Federated baseline vs $\epsilon=10$	Yes	No
Federated baseline vs $\epsilon=1$	No	Yes
Federated baseline vs $\epsilon=0.1$	No	Yes
$\epsilon=10$ vs $\epsilon=1$	No	Yes
$\epsilon=1$ vs $\epsilon=0.1$	Yes	No

Figure 4: Comparison of confidence intervals

To check whether the accuracy differences between environments reflect something real rather than just noise, 95% Wilson score confidence intervals were computed for each test's accuracy. If two environments have confidence intervals that don't overlap, their difference in accuracy is

statistically significant at the 95% level. If they overlap, the difference could plausibly be due to chance.

The results fall into three fairly clean groupings. The centralised baseline, federated baseline, $\epsilon=100$, and $\epsilon=10$ all produce overlapping confidence intervals — meaning that despite small numerical differences in accuracy, none of those differences are statistically distinguishable from one another. These four environments are essentially performing the same.

At $\epsilon=1$, the confidence interval [62.1%, 66.1%] no longer overlaps with the federated baseline or any of the higher-epsilon configurations, confirming that the accuracy drop is real and not an artifact. Importantly though, the $\epsilon=1$ interval also doesn't overlap with the naive baseline, which means the model is still extracting some useful signal even at strong privacy — it's noticeably worse, but not uninformative.

At $\epsilon=0.1$, the interval [59.1%, 63.1%] overlaps entirely with the naive baseline. Statistically, the maximally private model is the same as predicting that every patient is not pre-diabetic.

Appendix D: McNemar's Test

Confidence intervals tell us whether two models differ in overall accuracy, but they don't tell us whether they're making mistakes on the same patients. McNemar's test fills this gap. Rather than comparing accuracy rates, it looks at the pattern of disagreements between two models: how many patients did model A get right that model B got wrong, and vice versa. If these disagreements are roughly symmetric, the two models are effectively making the same errors and the difference between them is not meaningful. If one model systematically gets patients right that the other misses, that's a genuine difference in behaviour (Dietterich, 1998). McNemar's test is the standard choice for comparing two classifiers on the same test set.

Comparison	b (A✓ B×)	c (A× B✓)	χ^2	p-value	Significant?
BASELINE COMPARISONS					
Centralized vs federated baseline	240	185	6.86	0.009	Yes
FEDERATED BASELINE VS DIFFERENTIAL PRIVACY					
Federated baseline vs $\epsilon=100$	329	293	1.97	0.161	No
Federated baseline vs $\epsilon=10$	191	240	5.35	0.021	Yes
Federated baseline vs $\epsilon=1$	65	66	0.00	1.000	No
Federated baseline vs $\epsilon=0.1$	477	299	40.37	<0.001	Yes
KEY DP CONTRASTS					
$\epsilon=10$ vs $\epsilon=1$	241	193	5.09	0.024	Yes
$\epsilon=1$ vs $\epsilon=0.1$	474	295	41.20	<0.001	Yes

Figure 5: McNemar's test. b = patients model A classified correctly that model B did not; c = patients model B classified correctly that model A did not. $p < 0.05$ indicates the two models differ significantly in their pattern of errors on the same test set

The centralised versus federated baseline comparison comes back significant ($\chi^2=6.86$, $p=0.009$), which is unexpected given how close the accuracy numbers are. What this tells us is that even though federation barely changes overall accuracy, it does change which patients get misclassified.

The federated baseline versus $\epsilon=10$ comparison is also significant ($p=0.021$) despite a negligible accuracy difference, which points in the same direction: differential privacy at moderate levels is reshaping which patients the model gets wrong, even when the headline accuracy figure looks stable.

The most counterintuitive result is the federated baseline versus $\epsilon=1$ comparison, which is not significant ($p=1.000$) despite a seven percentage point accuracy drop. The comparison between $\epsilon=10$ and $\epsilon=1$ is significant ($p=0.024$), and the $\epsilon=0.1$ comparisons are all highly significant ($p<0.001$), consistent with a model that has essentially stopped functioning as a classifier.